

Laboratório — Sessão 6 (Desafio Mini-CTF)

Desafio Prático Integrador — Mini-CTF Defensivo Linux

Curso	Reskilling
Módulo	Linux e Cibersegurança
Objetivo de Aprendizagem	Integração de OA1 a OA5 (foco em Criar)
Duração da prática	19:15 – 20:50 (Hackathon Defensivo Partes 1 e 2)
Formador	Péricles Borges
Peso na avaliação	65% da nota final (Portfólio GitHub)

Cenário

O servidor Ubuntu da empresa fictícia "**Linux Agency**" apresenta indícios de atividade suspeita e configurações severamente inseguras. A sua missão é auditar, conter os danos, aplicar as correções e documentar toda a intervenção — como se fosse chamado a responder a um incidente real.

Ambiente Virtual

- **TryHackMe — Linux Agency** (gratuito): <https://tryhackme.com/room/linuxagency>
- **TryHackMe — Linux Incident Surface** (gratuito, alternativa): <https://tryhackme.com/room/linuxincidentsurface>

Escolha uma das duas salas como base do desafio, consoante orientação do formador em sala.

Metodologia de Resposta (Roteiro de Ações Exigidas)

Fase 1 — Identificação e Triagem

- ☐ Análise de Rede e Portas: identificar quais os portos e serviços ativos que estão expostos desnecessariamente

```
ss -tuln
nmap -sV localhost
```

- ☐ Auditoria de Contas: procurar por utilizadores com permissões excessivas, contas sem palavra-passe associada ou chaves públicas suspeitas em `authorized_keys`

```
sudo cat /etc/shadow | awk -F: '($2==""){print $1}'
cat ~/.ssh/authorized_keys
```

Fase 2 — Contenção

- ☐ Ativar a firewall UFW, bloqueando todas as portas que não sejam estritamente necessárias para o negócio

```
sudo ufw default deny incoming
sudo ufw allow 22/tcp
sudo ufw enable
```

Fase 3 — Enrijecimento / Remediação

- ☐ Corrigir a configuração do SSH de acordo com as boas práticas (desativar login root, bloquear passwords, migrar para chaves criptográficas)
- ☐ Aplicar patches de segurança relevantes identificados durante a triagem

Validação

- ☐ Correr a ferramenta Lynis para atestar a melhoria da postura de segurança global do host

```
sudo lynis audit system
```

Critérios de Entrega Obrigatória (Avaliação)

- Relatório Técnico de Auditoria e Mitigação** em formato Markdown (`README.md`), estruturado pelas três fases acima
- Ficheiros de configuração corrigidos** incluídos no repositório (cópia limpa do `sshd_config`, regras UFW exportadas)

3. **Publicação completa** deste ecossistema de evidências no Portfólio individual no GitHub, para avaliação formal do formador

Checklist de Submissão (Portfólio GitHub)

- ☐ Criar `sessao-06/README.md` com o Relatório Técnico completo (Identificação → Contenção → Remediação → Validação)
- ☐ Incluir `sessao-06/sshd_config` (cópia limpa, sem dados sensíveis)
- ☐ Incluir `sessao-06/ufw-rules.txt` (output de `ufw status verbose`)
- ☐ Incluir excerto do relatório Lynis final (score pós-hardening)
- ☐ Confirmar que o repositório está público ou partilhado com o formador
- ☐ Commit e push final antes do prazo de submissão